PHASE 01 / 21

Utilisateurs & sécurité

Comptes, authentification, rôles et protection du compte, sur backend, web et mobile.

Version	MVP
Complexité	Moyenne
Statut actuel	Environ 70 %
Prérequis	Phase 0

Modules couverts

- 1. Authentification & Utilisateurs
- 43. Sécurité

Étapes backend (dans cet ordre)

1. Mot de passe oublié : demande, email, confirmation, jeton 15 min à usage unique
2. Vérification de l'email et renvoi du lien
3. Changement de mot de passe avec révocation des sessions
4. Double authentification (TOTP) avec codes de secours
5. AuditLog : connexion, changement de mot de passe, 2FA, changement de rôle
6. Sessions actives : liste et révocation par appareil
7. Tests des permissions par rôle

Frontend web (Next.js)

- Brancher /auth/forgot-password sur l'API (aujourd'hui une maquette)
- Créer /auth/reset-password et /auth/verify-email
- Pages profil et paramètres (langue, fuseau, devise, mot de passe, 2FA, sessions)
- Validation de la case « conditions générales » côté serveur

Application mobile (Expo)

- Initialiser Expo (React Native + TypeScript)
- Écrans connexion et inscription, tokens dans SecureStore, refresh automatique
- Écran profil

Tests à écrire

- Reset : lien expiré, déjà utilisé, falsifié
- Aucune énumération de comptes
- 429 après dépassement du quota d'essais

Critère de sortie de la phase

[ ] Un utilisateur crée un compte, vérifie son email, se connecte, récupère son mot de passe, sur web et mobile

Pièges à éviter

! Ne pas bloquer la connexion sur is_verified trop tôt

! Ne jamais stocker les tokens en clair sur mobile